

**UNIVERSIDAD NACIONAL FEDERICO VILLARREAL
FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS**



INFORME DE DEFENSA EN PROFUNDIDAD Y CSMA

AUTOR

Quispe Mescua George Angel

CURSO

Ciberseguridad

2026

1. Introducción

El presente informe tiene carácter netamente informativo y tiene como propósito describir dos enfoques utilizados en la protección de sistemas de información: Defense in Depth (Defensa en Profundidad) y Cybersecurity Mesh (CSMA). Ambos modelos abordan la seguridad de la información desde perspectivas distintas: el primero desde una lógica de capas superpuestas de protección, y el segundo desde una arquitectura distribuida y modular orientada a entornos descentralizados. A continuación, se presenta la clasificación conceptual de cada modelo, en qué consiste, sus ventajas, desventajas, el contexto en el que resulta más apropiado aplicarlos, y finalmente un cuadro comparativo general entre ambos.

2. Objetivos

- Desplegar OWASP Juice Shop en un entorno local controlado mediante contenedores Docker.
- Ejecutar ataques representativos (inyección SQL, Cross-Site Scripting y fuerza bruta) sobre la aplicación sin ningún control de seguridad implementado.
- Implementar capas sucesivas de defensa (segmentación de red, proxy inverso, firewall perimetral y limitación de tasa de peticiones) siguiendo el modelo de Defensa en Profundidad.
- Repetir los ataques iniciales sobre el entorno protegido para verificar la efectividad de cada capa.
- Comparar los resultados obtenidos con los principios de la arquitectura de Cybersecurity Mesh.

3. Marco Teórico

3.1 Defensa en Profundidad

Modelo de seguridad centralizado y por capas concéntricas, en el que cada capa actúa como una barrera adicional frente a un atacante. Su premisa es que ningún control individual es infalible, por lo que la combinación de varios reduce la probabilidad de un compromiso total. Este modelo asume la existencia de un perímetro de red claramente definido.

Consiste en implementar múltiples capas o mecanismos de seguridad independientes entre sí, de manera que si un atacante logra vulnerar una de ellas, existan otras capas adicionales que continúen protegiendo el activo. Estas capas suelen abarcar distintos niveles de la infraestructura, entre ellos:

- Seguridad física: control de acceso a instalaciones, centros de datos y equipos.
- Seguridad perimetral: firewalls, sistemas de detección y prevención de intrusos (IDS/IPS).
- Seguridad de red: segmentación, VLANs, listas de control de acceso (ACL).
- Seguridad de host: antivirus, hardening de sistemas operativos, parches.

- Seguridad de aplicación: validación de entradas, control de sesiones, pruebas de vulnerabilidades.
- Seguridad de datos: cifrado, control de acceso basado en roles (RBAC), copias de respaldo.
- Políticas, capacitación y monitoreo: gobernanza, concientización del usuario y auditoría continua.

El principio rector es que ningún control debe considerarse infalible por sí solo; la seguridad se construye mediante la redundancia y la diversidad de mecanismos de protección.

3.1.2 Ventajas

- Reduce la probabilidad de que un único punto de fallo comprometa todo el sistema.
- Proporciona redundancia: si una capa falla, otras continúan operando.
- Modelo ampliamente probado, documentado y comprendido por la industria.
- Facilita el cumplimiento de normativas y estándares (ISO 27001, NIST, PCI DSS).
- Permite una implementación gradual, capa por capa, según presupuesto y prioridades.

3.1.3 Desventajas

- Puede generar complejidad operativa al administrar múltiples controles y herramientas.
- Costos elevados de implementación y mantenimiento al sumar capas adicionales.
- Enfoque predominantemente perimetral: puede ser menos eficaz ante entornos distribuidos, la nube o el trabajo remoto, donde el perímetro tradicional se diluye.
- Riesgo de falsa sensación de seguridad si las capas no se integran ni se monitorean de forma coordinada.
- Puede introducir latencia o fricción en el rendimiento de los sistemas al añadir sucesivos controles.

3.1.4 Aplicación

Defense in Depth resulta especialmente apropiado en organizaciones con infraestructura centralizada, redes corporativas tradicionales, centros de datos propios (on-premise) y entornos donde el perímetro de red está claramente definido. Es comúnmente aplicado en sectores como banca, gobierno, industria y organizaciones que gestionan infraestructura crítica, donde se requiere un control estricto y por capas del acceso a los sistemas y a la información.

3.2 Cybersecurity Mesh Architecture (CSMA)

Modelo de seguridad distribuido y centrado en la identidad, en el que cada activo, usuario o servicio cuenta con su propio perímetro de seguridad, independientemente de su ubicación física o de red. Los puntos de control se integran mediante analítica de seguridad compartida, gestión de identidad distribuida y políticas centralizadas con aplicación descentralizada. Surge como

respuesta a la disolución del perímetro tradicional en entornos híbridos, distribuidos y con trabajo remoto.

Consiste en desplegar controles de seguridad de manera distribuida y modular alrededor de cada activo o identidad individual (usuario, dispositivo, aplicación o dato), en lugar de concentrar la protección en un único perímetro. Cada nodo de la malla cuenta con su propio perímetro de seguridad definido y gestionado, pero todos los nodos se integran mediante una capa común de servicios compartidos, entre los que se incluyen:

- Gestión centralizada de identidad y políticas (Identity Fabric).
- Inteligencia de seguridad y analítica compartida entre todos los componentes.
- Gestión de postura de seguridad y cumplimiento distribuido (Security Posture Management).
- Consolas centralizadas de gestión, orquestación y respuesta ante incidentes.

Este modelo permite que la seguridad se adapte a entornos multinube, dispositivos móviles, trabajo remoto e infraestructuras híbridas, aplicando el principio de confianza cero (Zero Trust) a nivel de cada identidad y activo, en lugar de asumir confianza dentro de un perímetro definido.

3.2.2 Ventajas

- Se adapta de forma natural a entornos distribuidos, multinube e híbridos.
- Escalabilidad: los controles se despliegan de forma modular según se incorporan nuevos activos.
- Mayor coherencia y visibilidad centralizada de políticas, aun cuando la infraestructura esté distribuida.
- Compatible con el modelo de confianza cero (Zero Trust), reforzando la verificación continua de identidad.
- Mayor flexibilidad para responder a entornos cambiantes, como el trabajo remoto o la adopción acelerada de servicios en la nube.

3.2.3 Desventajas

- Modelo relativamente reciente, con menor madurez, documentación y estandarización que los modelos tradicionales.
- Requiere inversión en herramientas de orquestación e integración entre proveedores y plataformas.
- Mayor complejidad de diseño inicial, al requerir coordinación entre múltiples nodos y proveedores de seguridad.
- Dependencia de la interoperabilidad entre soluciones de distintos fabricantes, lo cual no siempre está garantizado.
- Curva de aprendizaje y necesidad de personal capacitado en arquitecturas modernas de seguridad distribuida.

3.2.4 Aplicación

Cybersecurity Mesh resulta especialmente apropiado en organizaciones con infraestructura distribuida, entornos multinube, adopción de modelos de trabajo remoto o híbrido, uso extendido de dispositivos móviles (BYOD) y ecosistemas de aplicaciones como servicio (SaaS). Es un enfoque frecuentemente adoptado por organizaciones en proceso de transformación digital, que requieren proteger identidades y activos independientemente de su ubicación, sin depender de un perímetro de red fijo.

4. Cuadro Comparativo

Criterio	Defense in Depth	Cybersecurity Mesh
Enfoque estructural	Capas superpuestas de seguridad en torno a un perímetro definido	Nodos de seguridad distribuidos en torno a cada identidad o activo
Origen del modelo	Enfoque tradicional, derivado de principios de defensa militar	Enfoque moderno, propuesto para arquitecturas distribuidas y en la nube
Gestión de confianza	Confianza generalmente asociada al perímetro de red	Basado en el principio de confianza cero (Zero Trust)
Escalabilidad	Escalabilidad limitada; añadir capas incrementa la complejidad	Alta escalabilidad; los nodos se integran de forma modular
Entorno ideal	Infraestructura centralizada y redes corporativas tradicionales (on-premise)	Entornos distribuidos, multinube, híbridos y trabajo remoto
Madurez y adopción	Modelo consolidado, ampliamente documentado y adoptado	Modelo emergente, en proceso de estandarización
Complejidad de gestión	Aumenta con el número de capas implementadas	Aumenta con la necesidad de interoperabilidad entre nodos
Costo relativo	Costos crecientes por la suma de controles independientes	Inversión inicial en orquestación e integración de plataformas

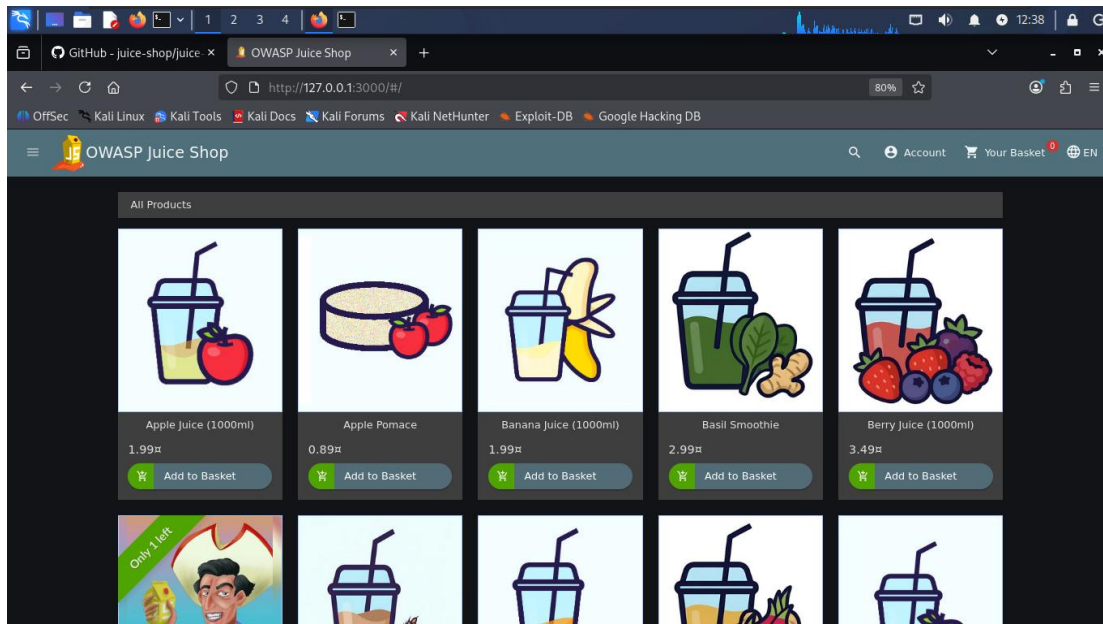
5. Entorno del Laboratorio

- Aplicación objetivo: OWASP Juice Shop (imagen oficial bkimminich/juice-shop), ejecutada en contenedor Docker.
- Equipo atacante: Kali Linux, con Burp Suite Community Edition como herramienta principal de explotación e intrusión.
- Componentes de defensa: red Docker dedicada (juice_net), proxy inverso Nginx, firewall de host (ufw) y Web Application Firewall basado en ModSecurity con OWASP Core Rule Set.

6. Fase 1: Evaluación sin Controles de Seguridad

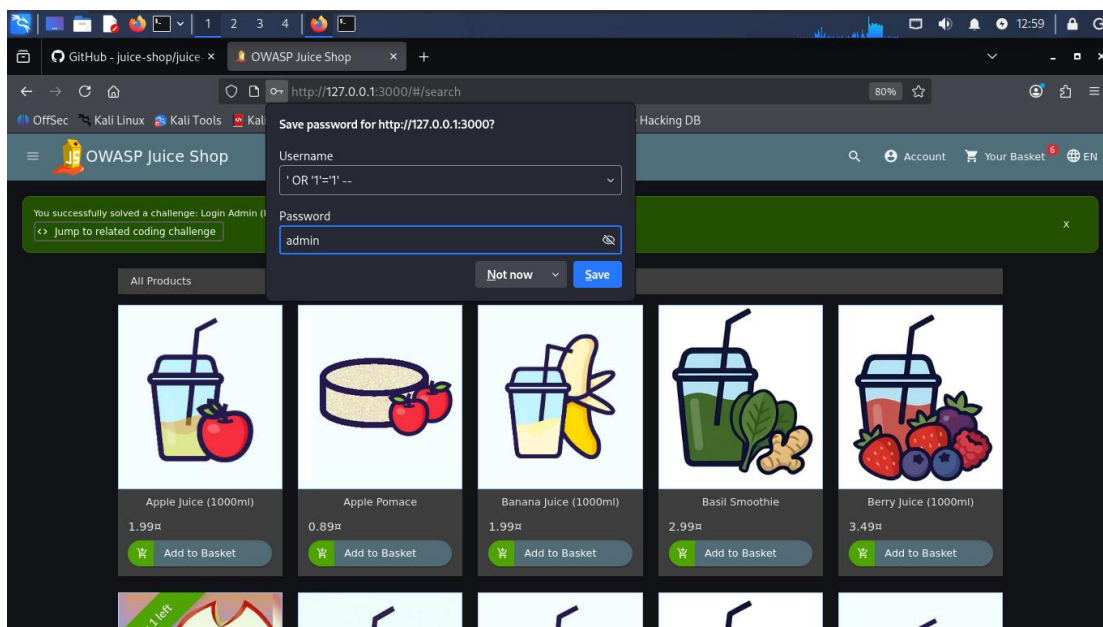
En esta fase se accedió directamente a la aplicación Juice Shop expuesta sin ningún mecanismo de protección, con el objetivo de establecer una línea base de vulnerabilidad.

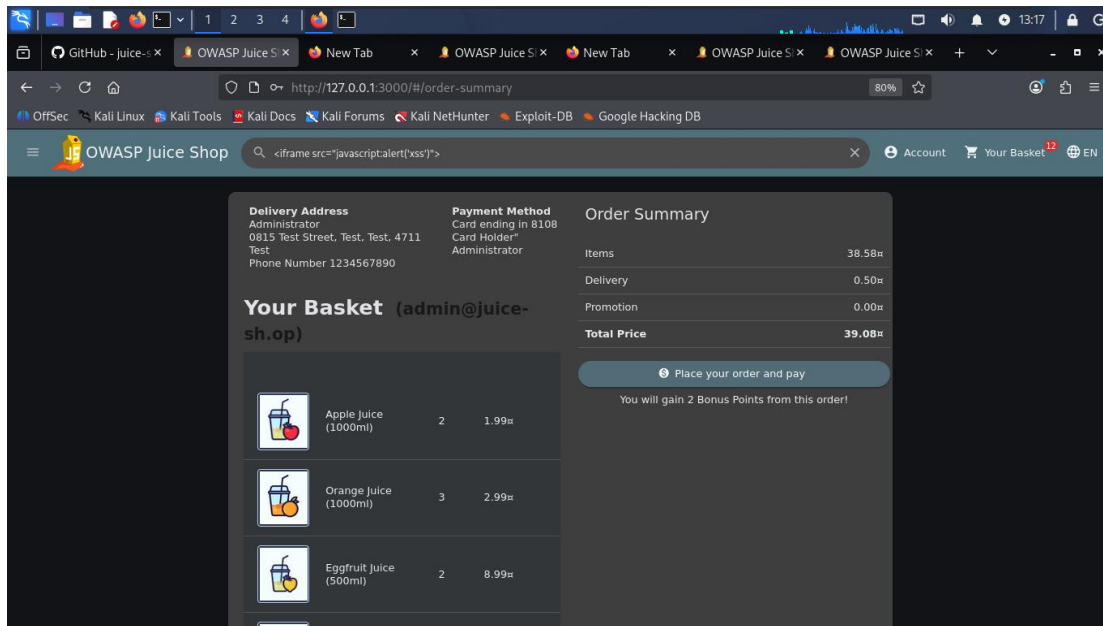
6.1 Acceso inicial a la aplicación



6.2 Inyección SQL (SQLi) en formulario de login

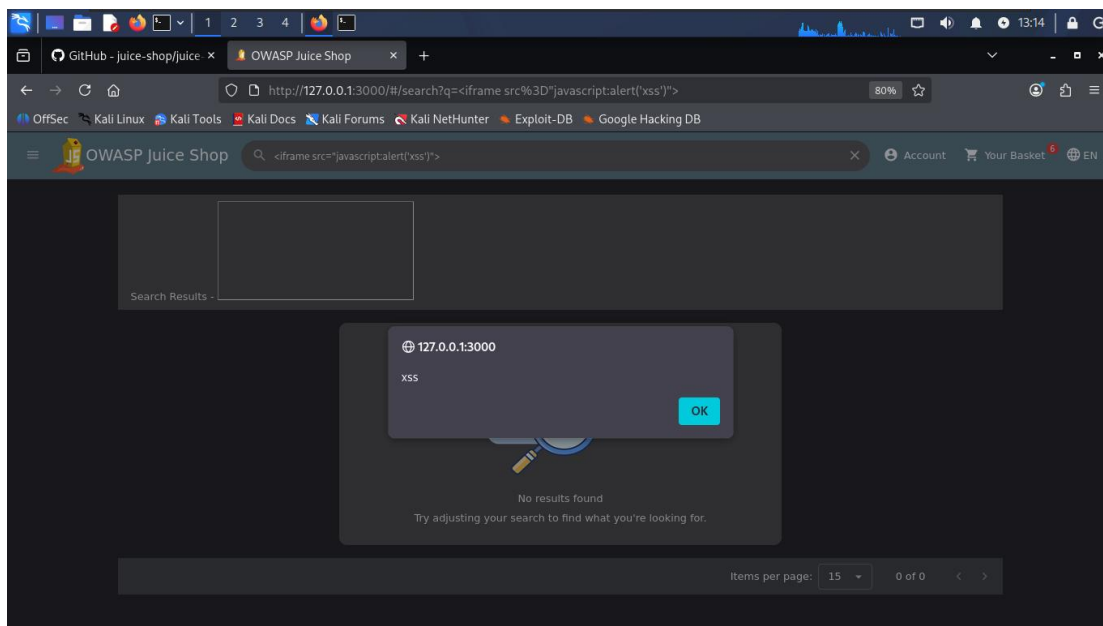
Se utilizó el payload ' OR '1'='1' -- en el campo de usuario, logrando autenticarse como administrador sin credenciales válidas.

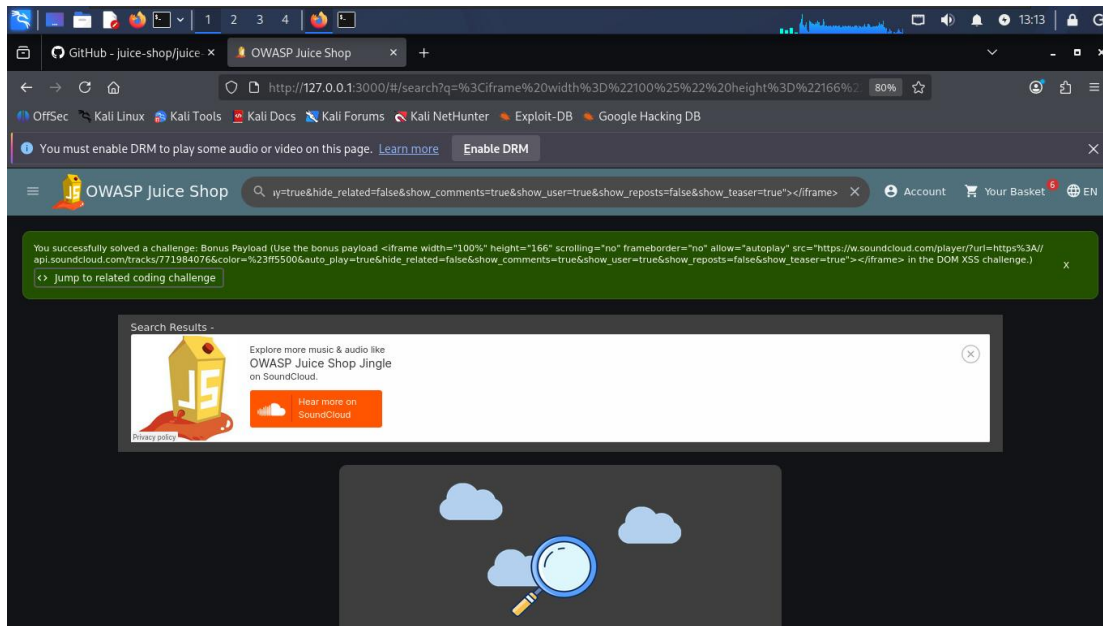




6.3 Cross-Site Scripting (XSS)

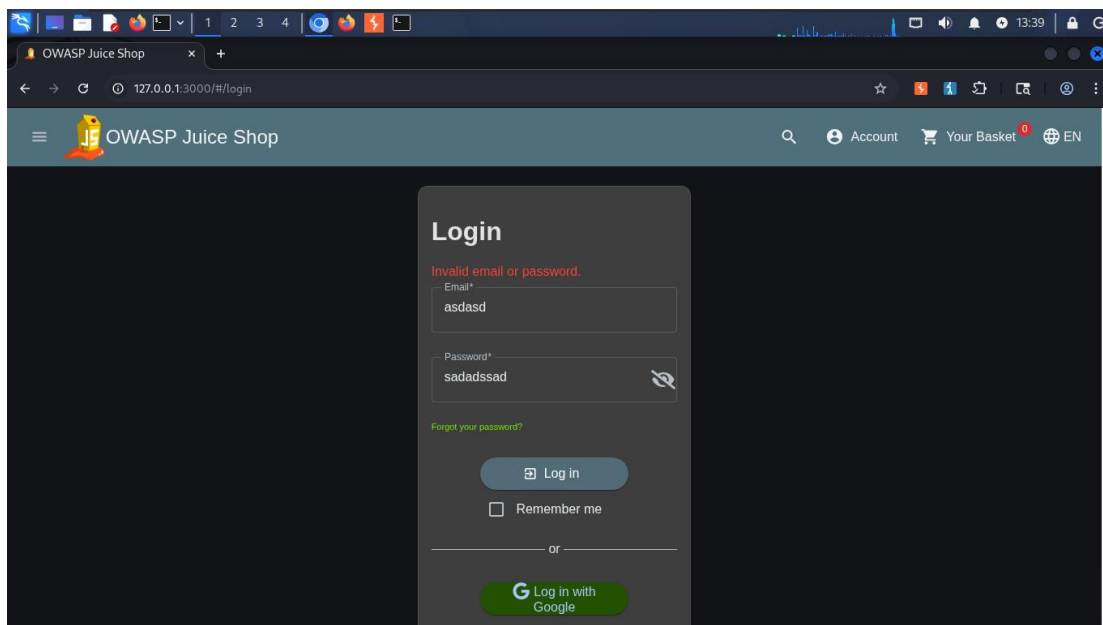
Se inyectaron payloads de XSS reflejado y DOM-based a través del campo de búsqueda, logrando ejecución de código en el navegador de la víctima.

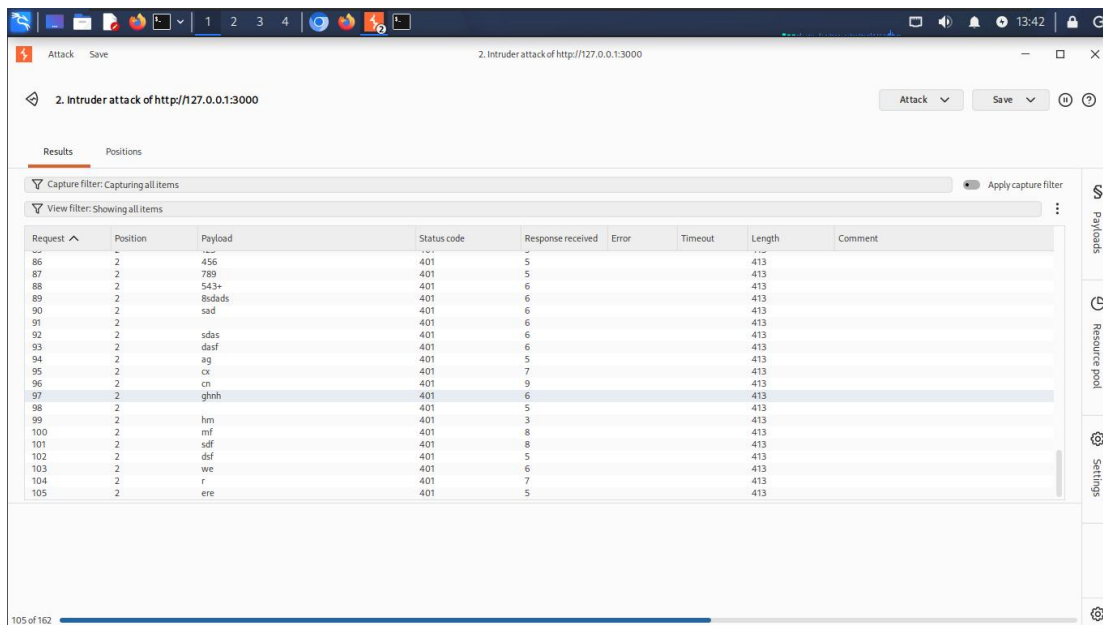
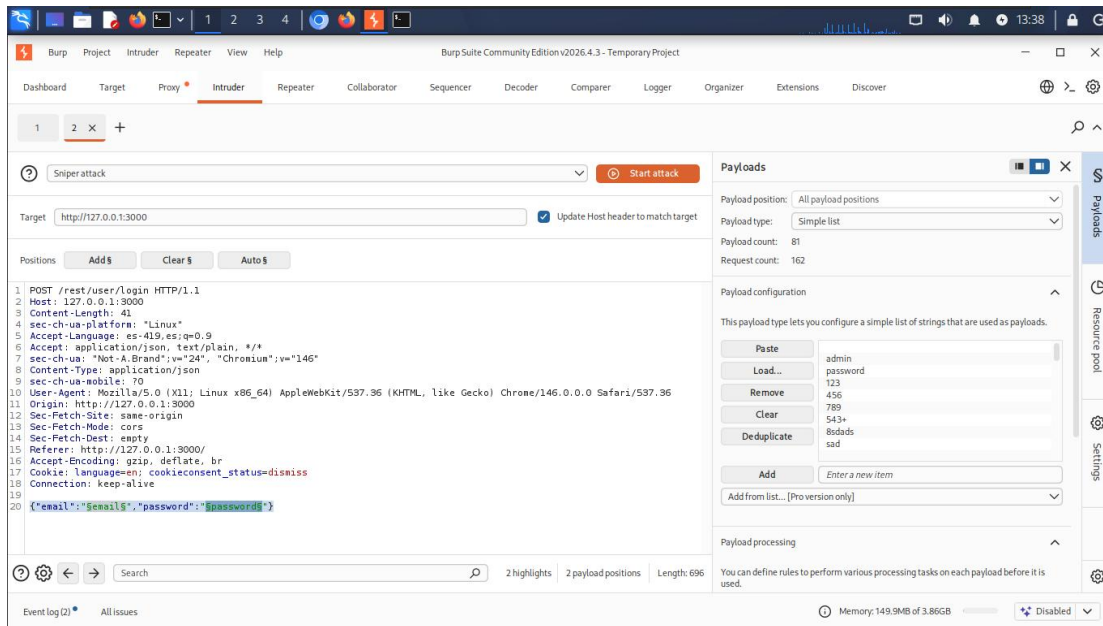




6.4 Fuerza bruta sobre el endpoint de autenticación

Se intentaron credenciales inválidas de forma manual y posteriormente de forma automatizada contra el endpoint `/rest/user/login`, sin que la aplicación aplicara ningún tipo de bloqueo o limitación.





6.5 Resumen de hallazgos

Ataque	Resultado sin controles
SQLi	Llega a la app y puede alterar el flujo de autenticación
XSS	La entrada llega al navegador y se ejecuta sin sanitización
Fuerza bruta	Múltiples intentos permitidos sin

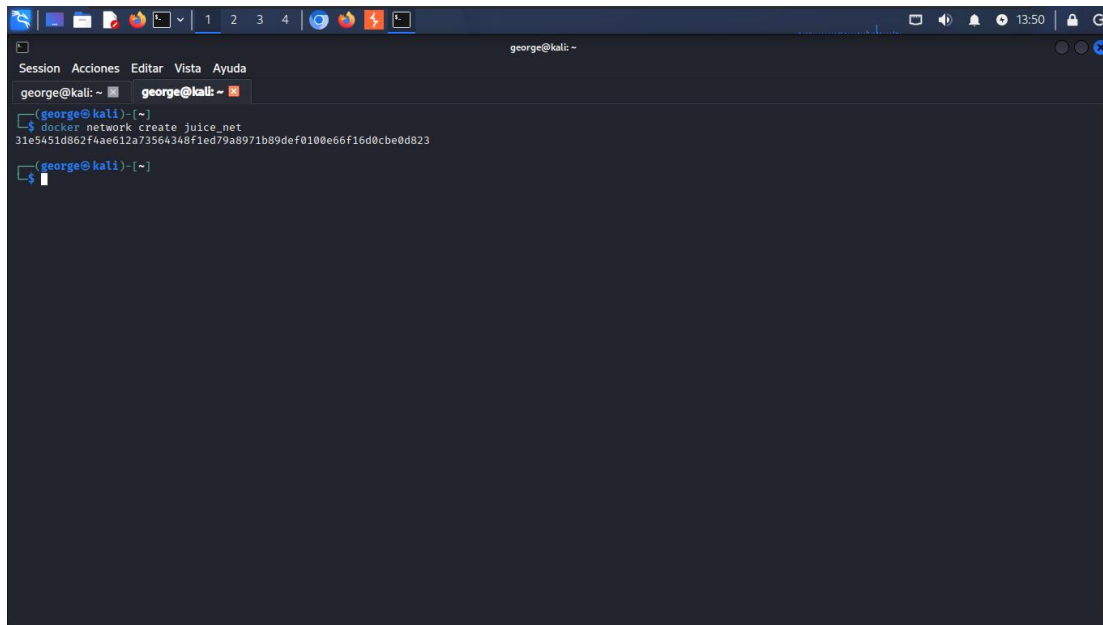
bloqueo ni retardo

7. Fase 2: Implementación de Defensa en Profundidad

A partir de los hallazgos de la Fase 1, se incorporaron capas de seguridad de forma incremental, repitiendo los mismos ataques tras cada capa para medir su efectividad.

7.1 Segmentación de red y proxy inverso

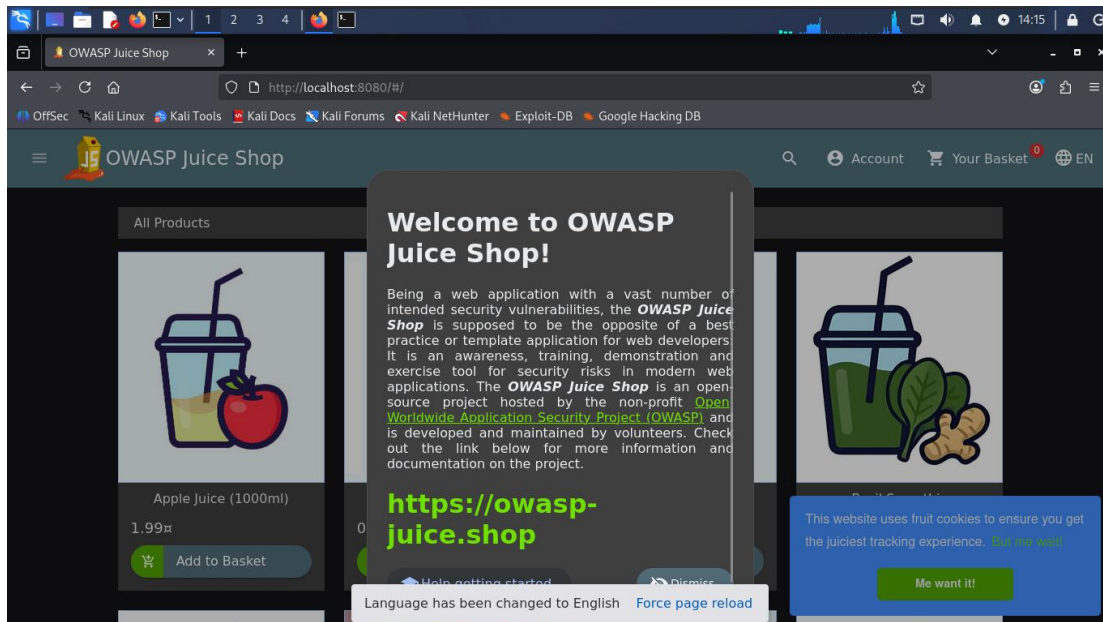
Se creó una red Docker aislada para los contenedores y se eliminó la exposición directa del puerto de la aplicación, forzando todo el tráfico a pasar por un proxy inverso Nginx.



```
Session Acciones Editar Vista Ayuda
george@kali: ~
(george@kali)-[~]
$ docker network create juice_net
31e5451d862f4ae612a73564348f1ed79a8971b89def0100e6f16d0cbe0d823
(george@kali)-[~]
```

```
(george@kali)-[~]
$ docker run -d \
  --name juice-shop \
  --network juice_net \
  bkimminich/juice-shop
aaa42a46039f56e965c882a55f0fa55ee1e21b1ad1ec8b2b1f4e944ed8c1ea3c
```

```
george@kali: ~  
GNU nano 9.0 nginx.conf *  
events {}  
  
http {  
    upstream juice_backend {  
        server juice-shop:3000;  
    }  
  
    server {  
        listen 80;  
        server_name _;  
  
        location / {  
            proxy_pass http://juice_backend;  
            proxy_set_header Host $host;  
            proxy_set_header X-Real-IP $remote_addr;  
            proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;  
            proxy_set_header X-Forwarded-Proto $scheme;  
        }  
    }  
}
```



```

    },
    "ConfigOnly": false,
    "Containers": {
      "56f8ba27bf990665e3cfa1448ef067318ca6911d867e58c67975ce9a1be301cd": {
        "Name": "juice-nginx",
        "EndpointID": "6c088f0fc2a3d4ce50ac837ac59605da9d9351c451e6f03f4b5f777de8a792bf",
        "MacAddress": "7a:8d:8d:33:8a:b4",
        "IPv4Address": "172.19.0.3/16",
        "IPv6Address": ""
      },
      "aaa42a46039f56e965c882a55f0fa55ee1e21b1ad1ec8b2b1f4e944ed8c1ea3c": {
        "Name": "juice-shop",
        "EndpointID": "7ca90e41b8ff1917272afad4ac77a704cfc785dae243d360b2524e43e58a32de",
        "MacAddress": "96:76:14:f2:5f:fa",
        "IPv4Address": "172.19.0.2/16",
        "IPv6Address": ""
      }
    },
    "Options": {},
    "Labels": {}
  }
}

```

```

(george@kali)-[~]
$ sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 8080/tcp
sudo ufw enable
sudo ufw status verbose
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
Rules updated
Rules updated (v6)
Firewall is active and enabled on system startup
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip

To Action From
--
8080/tcp ALLOW IN Anywhere
8080/tcp (v6) ALLOW IN Anywhere (v6)

```

7.2 Limitación de tasa de peticiones en Nginx

Sobre la capa de perímetro ya establecida, se configuró control de tasa de peticiones a nivel de proxy inverso, con un límite estricto para el endpoint de autenticación y un límite general para el resto de la aplicación.

```

limit_req_zone $binary_remote_addr zone=login_limit:10m rate=5r/m;
limit_req_zone $binary_remote_addr zone=global_limit:10m rate=30r/m;

upstream juice_backend {
    server juice-shop:3000;
}

server {
    listen 80;
    server_name _;

    location /rest/user/login {
        limit_req zone=login_limit burst=3 nodelay;

        proxy_pass http://juice_backend;

        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }

    location / {
        limit_req zone=global_limit burst=20 nodelay;
    }
}

```

```

(george@kali)-[~]
$ docker exec juice-nginx nginx -t
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful

```

```

(george@kali)-[~]
$ docker exec juice-nginx nginx -s reload
2026/06/24 20:56:17 [notice] 36#36: signal process started

```

Attack Save 2. Intruder attack of http://localhost:8080

2. Intruder attack of http://localhost:8080

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

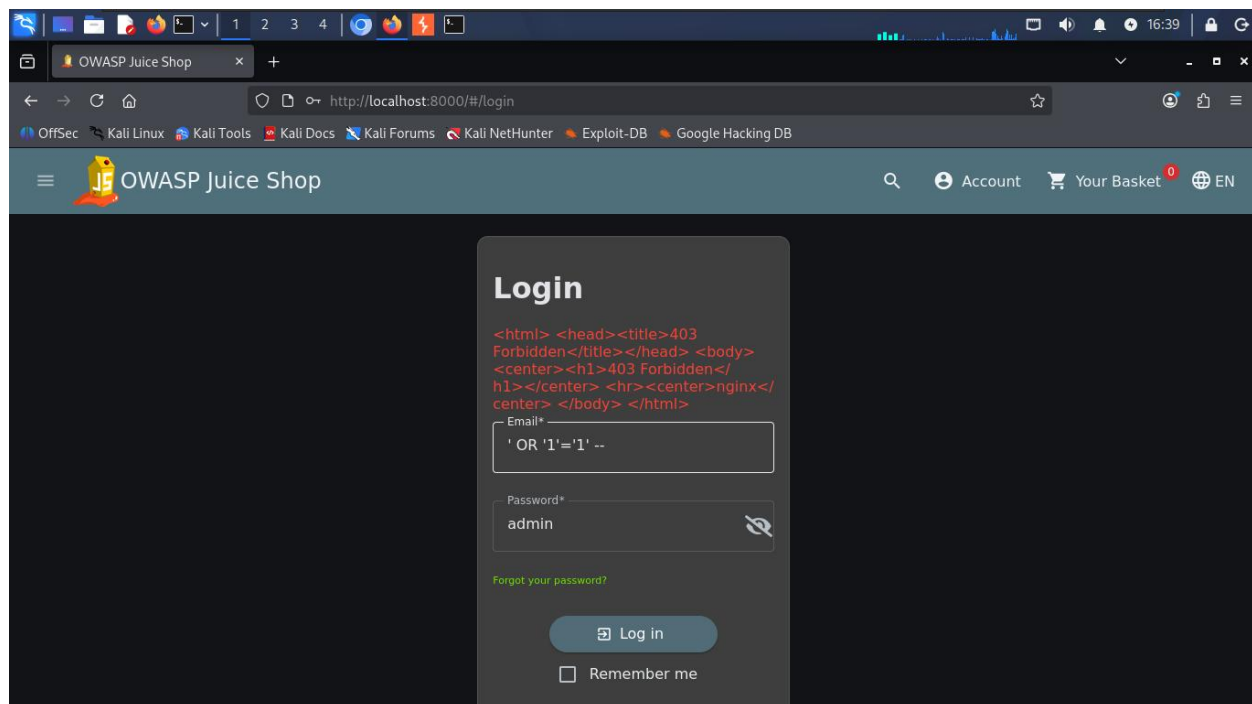
Request	Position	Payload	Status code	Response received	Error	Timeout	Length	Comment
0	0		401	35			412	
1	1		401	13			412	
2	1		401	13			412	
3	1	<zxox	401	8			412	
4	1	asdadaf	503	0			776	
5	1	gsaxovv	503	0			776	
6	1	bo	503	0			776	
7	1	fas	503	0			776	
8	1	asdasds	503	0			776	
9	1	sad	503	0			776	
10	1	dsadasda	503	0			776	
11	1	asdasdas	503	0			776	
12	1	sdsasgr	503	0			776	
13	1	bfstb	503	0			776	
14	1	difqeqgd	503	0			776	
15	1	qwfasvd	503	0			776	
16	1	sdadad	503	0			776	
17	1	hghstf	503	0			776	
18	1	hghstfscvn	503	1			776	
19	1	dfsd	503	0			776	
20	1	hghsdgf	503	0			776	
21	1	fhvov	503	0			776	

23 of 104

7.3 Web Application Firewall (WAF)

Como capa adicional de defensa orientada a la aplicación, se desplegó un Web Application Firewall basado en ModSecurity con el OWASP Core Rule Set (CRS), posicionado igualmente como intermediario del tráfico hacia la aplicación.

```
(george@kali)-[~]
$ docker run -d \
  --name juice-waf \
  --network juice_net \
  -p 8000:80 \
  -v $(pwd)/nginx.conf:/etc/nginx/conf.d/default.conf:ro \
  owasp/modsecurity-crs:nginx
f1ceba3d2c522fbc7293028c641e86ac0b47ad643a0c719c17202e183c11d6c4
```



7.4 Resumen de hallazgos

Capa aplicada	Control implementado	Efecto observado
Perímetro / Red	Red Docker aislada, proxy inverso Nginx, firewall UFW	Se elimina el acceso directo al contenedor de la aplicación; todo el tráfico se centraliza en un único punto de entrada
Aplicación (tasa)	Rate limiting en Nginx	El ataque de fuerza bruta es bloqueado (HTTP 503) tras

		superar el umbral configurado
Aplicación (WAF)	ModSecurity y OWASP CRS	Capa adicional para inspección de payloads (SQLi/XSS) a nivel de aplicación

8. Comparativa Final: Defense in Depth - Cybersecurity Mesh

A partir de los resultados obtenidos en el laboratorio, se contrastan ambos modelos de seguridad. El laboratorio implementado corresponde íntegramente al modelo de Defensa en Profundidad, dado que se trata de un único activo (Juice Shop) protegido mediante capas concéntricas centralizadas en torno a un perímetro común (el proxy inverso). La siguiente tabla resume las diferencias conceptuales con el modelo de Cybersecurity Mesh, aplicable a escenarios distribuidos.

Criterio	Defense in Depth	Cybersecurity Mesh (CSMA)
Punto de control	Centralizado en el perímetro (proxy/firewall)	Distribuido, asociado a cada identidad o activo
Modelo de confianza	Implícita una vez dentro del perímetro	Continua y verificada (enfoque Zero Trust)
Punto único de falla	Sí: si se compromete el proxy/perímetro, el resto queda expuesto	No: el compromiso de un nodo no otorga acceso automático a los demás
Escalabilidad en entornos híbridos/cloud	Baja; requiere reforzar el perímetro por cada nuevo punto de acceso	Alta; cada nuevo activo incorpora su propio perímetro de identidad
Visibilidad	Fragmentada por capa (red, host, aplicación)	Unificada mediante dashboards y analítica consolidada
Aplicabilidad al laboratorio realizado	Total: red segmentada, proxy, firewall y rate limiting alrededor de un único activo	Conceptual: requeriría replicar el control de identidad por cada microservicio si la app se descompusiera en varios componentes distribuidos

9. Conclusiones

- La ausencia de controles permitió la explotación inmediata de SQLi, XSS y fuerza bruta sobre Juice Shop, validando la línea base de vulnerabilidad establecida en la Fase 1.
- La implementación progresiva de capas (segmentación de red, proxy inverso, firewall y rate limiting) demostró ser efectiva para contener específicamente el ataque de fuerza bruta, evidenciado por el cambio de código de respuesta de 401 a 503 tras superar el umbral configurado.
- El modelo de Defensa en Profundidad resulta adecuado para escenarios centralizados como el del laboratorio, donde existe un único activo y un perímetro claramente definible.
- El modelo de Cybersecurity Mesh se vuelve relevante cuando el escenario se distribuye en múltiples activos, identidades o entornos (cloud, remoto, microservicios), donde un perímetro único deja de ser representativo de la superficie de ataque real.
- Ambos modelos no son mutuamente excluyentes: la Defensa en Profundidad puede entenderse como la base de control por capas que, al distribuirse y centrarse en la identidad de cada activo, evoluciona hacia un enfoque de Cybersecurity Mesh en entornos más complejos.